

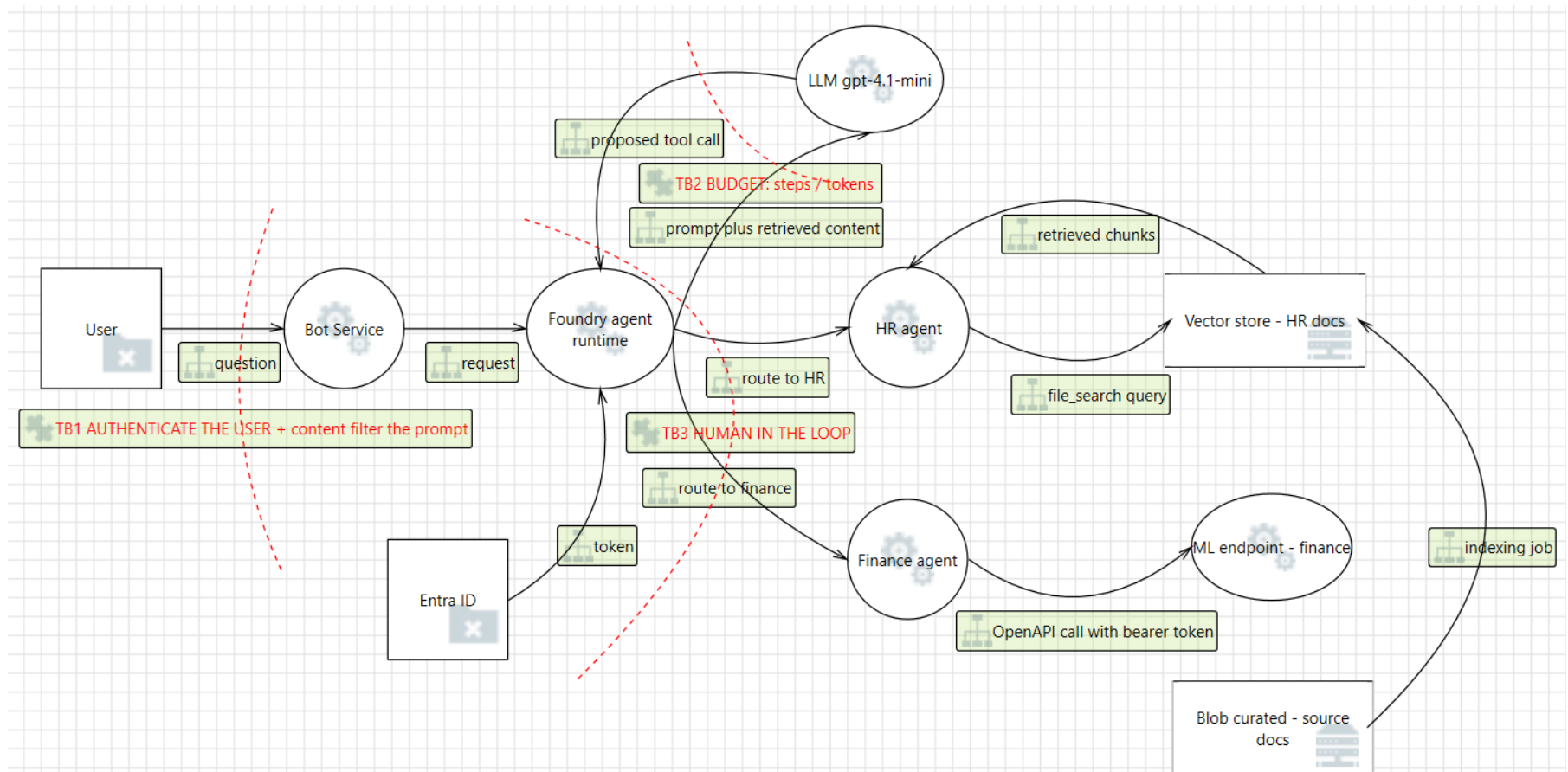


Agentic AI Worksheet for Threat Modeling

Data Flow Diagram (DFD)

The Data Flow Diagram shows how a question travels through the agentic system: a user asks the bot, the agent runtime decides what to do, and specialist agents reach a document index or a fine-tuned model endpoint. Each trust boundary is drawn as a red dashed line at the point where data or control passes between areas of different trust.

Two of these boundaries do not exist in a conventional application, and they are where most of the risk sits. The first is between the runtime and the model: everything the model emits, including the tool calls it proposes, is untrusted input. The second is between retrieved content and the agent: a document can carry instructions, and the agent has no way to tell them apart from the text it was asked to summarise.



STRIDE Threat Modeling

The STRIDE table takes each security control, says which trust boundary it protects, and names the threat it exists to stop. Read it in that order: the control is the answer, the threat is the question it answers.

Control ID	Control Title	Modified Control Description	Trust Boundary	Threat Type	Threat Description
C-01	User authentication and prompt filtering	Every request carries a signed user identity, and the prompt is content-filtered before the agent runtime sees it.	TB-01	Spoofing	Without an authenticated caller, anyone reaching the bot can act as a legitimate employee and ask the agent for another person's data.
C-02	Agent loop budget	The loop stops after 6 steps, 20,000 tokens or 180 seconds, checked before every pass, and cancels the run.	TB-02	Denial of Service	A prompt that makes the agent loop on itself consumes tokens until the budget is exhausted - denial of wallet as much as denial of service.
C-03	Human approval before any write	A tool that changes state cannot run until a person approves that specific call.	TB-03	Elevation of Privilege	The model proposes a payment approval it was never asked for, and it executes with the agent's permissions rather than the user's.
C-04	Tool argument validation	Arguments are checked against a system of record the model cannot read or change: the record must exist and be within threshold.	TB-03	Tampering	The model invents an invoice number or an amount and the value is taken on trust, so a fabricated record is paid.
C-05	Per-task tool allow-list	An agent is bound only to the tools its task needs, and the loop refuses any call outside that list.	TB-02, TB-03	Elevation of Privilege	An agent built with a write tool for one task can be talked into using it during another, widening blast radius beyond the task.
C-06	Grounding and citation of retrieved content	Answers cite the source document, and instructions found inside retrieved text are never executed.	TB-04	Tampering	Indirect prompt injection: text planted in a document is read back as instructions, so the attacker controls the agent without ever talking to it.
C-07	Retrieval corpus integrity	Only reviewed documents are indexed, and the indexing job records what was ingested and by whom.	TB-07	Tampering	A poisoned document enters the index before anyone asks a question, so every later answer is affected and the prompt looks innocent.
C-08	Per-agent identity and least privilege	Each agent carries its own identity with permissions scoped to the data it is allowed to reach.	TB-06	Elevation of Privilege	All agents share one managed identity, so compromising the HR agent reaches the finance endpoint as well.
C-09	Scoped tokens for server-side tools	Tokens issued to a tool are audience-scoped and short-lived, and the endpoint authorises per call.	TB-05	Information Disclosure	A server-side tool call never returns to the caller's code, so a broad token is the only control left on that path.
C-10	Continuous evaluation and trace retention	Every completed response is scored by a rule bound to the agent, and traces are retained as evidence.	TB-02, TB-03	Repudiation	Without a record produced outside the agent, nobody can show what the agent did, or prove a bad answer was caught.

DREAD Risk Assessment

DREAD puts a number on each control so they can be ordered. Score each category 1 (minor), 2 (moderate) or 3 (major), then total: 1-7 Minor, 8-11 Moderate, 12-15 Major.

Control ID	Control Title	Modified Control Description	D (Damage Potential)	R (Reproducibility)	E (Exploitability)	A (Affected Users)	D (Discoverability)	Total Score	Risk Level
C-01	User authentication and prompt filtering	Signed identity on every request; prompt content-filtered before the runtime.	3	2	2	3	2	12	Major
C-02	Agent loop budget	6 steps / 20,000 tokens / 180 seconds, checked before every pass.	2	3	3	2	3	13	Major
C-03	Human approval before any write	A person approves each state-changing call before it runs.	3	2	2	3	2	12	Major
C-04	Tool argument validation	Arguments checked against a record the model cannot reach.	3	3	2	3	2	13	Major
C-05	Per-task tool allow-list	Agent bound only to the tools the task requires.	3	2	2	2	2	11	Moderate
C-06	Grounding and citation of retrieved content	Cite the source; never execute instructions found in a document.	3	3	3	3	3	15	Major
C-07	Retrieval corpus integrity	Only reviewed documents are indexed; ingestion is recorded.	3	2	2	3	2	12	Major
C-08	Per-agent identity and least privilege	Each agent has its own scoped identity.	3	2	2	3	3	13	Major
C-09	Scoped tokens for server-side tools	Audience-scoped, short-lived tokens; endpoint authorises per call.	2	2	2	2	2	10	Moderate
C-10	Continuous evaluation and trace retention	Responses scored by a rule bound to the agent; traces retained.	2	1	1	2	2	8	Moderate